ZAP by Checkmarx Scanning Report

Site: http://vapt-fixture-juice:3000

Generated on Wed, 7 Oct 2026 13:50:21

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	1
Informational	1
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	12
Info	Informational	http://vapt-fixture-juice:3000	Percentage of responses with status code 2xx	91 %
Info	Informational	http://vapt-fixture-juice:3000	Percentage of responses with status code 4xx	8 %
Info	Informational	http://vapt-fixture-juice:3000	Percentage of endpoints with content type application/javascript	4 %
Info	Informational		Percentage of endpoints with content	7 %

		http://vapt-fixture-juice:3000	type application /octet-stream	
Info	Informational	http://vapt-fixture-juice:3000	Percentage of endpoints with content type image /x-icon	1 %
Info	Informational	http://vapt-fixture-juice:3000	Percentage of endpoints with content type text /css	1 %
Info	Informational	http://vapt-fixture-juice:3000	Percentage of endpoints with content type text /html	78 %
Info	Informational	http://vapt-fixture-juice:3000	Percentage of endpoints with content type text /markdown	4 %
Info	Informational	http://vapt-fixture-juice:3000	Percentage of endpoints with content type text /plain	1 %
Info	Informational	http://vapt-fixture-juice:3000	Percentage of endpoints with method GET	100 %
Info	Informational	http://vapt-fixture-juice:3000	Count of total endpoints	65
Info	Informational	http://vapt-fixture-juice:3000	Percentage of slow responses	64 %

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Cross-Domain Misconfiguration	Medium	Systemic
Timestamp Disclosure - Unix	Low	Systemic

Modern Web Application	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://vapt-fixture-juice:3000
Node Name	http://vapt-fixture-juice:3000
Method	GET
Attack	
Evidence	
Other Info	
URL	http://vapt-fixture-juice:3000/
Node Name	http://vapt-fixture-juice:3000/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://vapt-fixture-juice:3000/ftp
Node Name	http://vapt-fixture-juice:3000/ftp
Method	GET
Attack	
Evidence	
Other Info	
URL	http://vapt-fixture-juice:3000/sitemap.xml
Node Name	http://vapt-fixture-juice:3000/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	**Cross-Domain Misconfiguration**
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	http://vapt-fixture-juice:3000
Node Name	http://vapt-fixture-juice:3000
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://vapt-fixture-juice:3000/assets/public/favicon_js.ico
Node Name	http://vapt-fixture-juice:3000/assets/public/favicon_js.ico
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://vapt-fixture-juice:3000/robots.txt
Node Name	http://vapt-fixture-juice:3000/robots.txt
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://vapt-fixture-juice:3000/scripts.js

Node Name	http://vapt-fixture-juice:3000/scripts.js
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	Systemic
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Low	**Timestamp Disclosure - Unix**
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://vapt-fixture-juice:3000/sitemap.xml
Node Name	http://vapt-fixture-juice:3000/sitemap.xml
Method	GET
Attack	
Evidence	1666666667
Other Info	1666666667, which evaluates to: 2022-10-25 02:57:47.
URL	http://vapt-fixture-juice:3000/styles.css
Node Name	http://vapt-fixture-juice:3000/styles.css
Method	GET
Attack	
Evidence	1528301887
Other Info	1528301887, which evaluates to: 2018-06-06 16:18:07.
URL	http://vapt-fixture-juice:3000/styles.css
Node Name	http://vapt-fixture-juice:3000/styles.css
Method	GET
Attack	
Evidence	1578947368
Other	

Info	1578947368, which evaluates to: 2020-01-13 20:29:28.
URL	http://vapt-fixture-juice:3000/styles.css
Node Name	http://vapt-fixture-juice:3000/styles.css
Method	GET
Attack	
Evidence	1602209945
Other Info	1602209945, which evaluates to: 2020-10-09 02:19:05.
URL	http://vapt-fixture-juice:3000/styles.css
Node Name	http://vapt-fixture-juice:3000/styles.css
Method	GET
Attack	
Evidence	1636363636
Other Info	1636363636, which evaluates to: 2021-11-08 09:27:16.
Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Informational	**Modern Web Application**
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://vapt-fixture-juice:3000
Node Name	http://vapt-fixture-juice:3000
Method	GET
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://vapt-fixture-juice:3000/
Node Name	http://vapt-fixture-juice:3000/
Method	GET
Attack	
	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },

Evidence	"button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://vapt-fixture-juice:3000/juice-shop/build/routes/fileServer.js:68:18
Node Name	http://vapt-fixture-juice:3000/juice-shop/build/routes/fileServer.js:68:18
Method	GET
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://vapt-fixture-juice:3000/juice-shop/node_modules/express/lib/router/index.js:328:13
Node Name	http://vapt-fixture-juice:3000/juice-shop/node_modules/express/lib/router/index.js:328:13
Method	GET
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://vapt-fixture-juice:3000/sitemap.xml
Node Name	http://vapt-fixture-juice:3000/sitemap.xml
Method	GET
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109